Bi-Weekly Project Progress Report & Meeting Agenda

雙週專案進度報告與會議議程 (Meeting #1)

Course: 03CIT4067 Cybersecurity Project | **Date:** October 06, 2026(Week5)

Project Title: Topic 15: Design and Implementation of a Web Application Security Risk Detection and Remediation Demonstration System Based on OWASP Top 10

Team Leader: WONG Lai Man (24810493) | **Supervisor:** LIAM XU

Team Members: Mustafa, Zoutao | **Meeting Phase:** Phase 1 - Proposal & Inception

---

1. Meeting Agenda (會議議程)

(預計會議時間：15-20 分鐘)

1. **Project Scope & Standard Confirmation (專案範圍與標準確認)**: Confirming Topic 15 and the adoption of the latest **OWASP Top 10: 2025** standard.
2. **Sprint 1 Review: Environment Setup & Red/Blue Team Exercise (Sprint 1 審查：環境設置與紅藍隊演練)**:
   - Demo of local deployment using **OWASP Juice Shop** via Docker.
   - Presentation of Red/Blue Team attack & defense analysis on OWASP 2021 vs 2025.
3. **Phase 1 Deliverables Checklist (Phase 1 交付物檢查表)**: Reviewing the progress of the Proposal, Literature Review, and APA 7th References.
4. **WBS & Gantt Chart Planning (WBS 與甘特圖規劃)**: Defining the roadmap for Term 1 and Term 2.
5. **Blockers & Next Steps (阻礙與下一步行動)**: Discussing technical challenges and assigning tasks for the next sprint.

2. Sprint 1 Review: What We Have Done (Sprint 1 審查)

2.1 Environment Setup & Tool Selection (環境設置與工具選型)

- **Decision (決定)**: Selected **OWASP Juice Shop** as the foundational shooting range (靶場) for secondary development due to its comprehensive modern vulnerability coverage.
- **Execution (執行)**: Deployed environment locally using Docker for isolation and safety.

```
        sudo docker pull bkimminich/juice-shop && sudo docker run --rm -p 127.0.0.1:3000:3000 bk
imminich/juice-shop
```

2.2 Red/Blue Team Exercise: OWASP 2021 vs 2025 Analysis

Team member (Mustafa) conducted a comprehensive Red/Blue team simulation. Executive Summary below (detailed logs available in Appendix A):

OWASP Category (2025)	Red Team Findings (Attack / 攻擊發現)	Blue Team Strategy (Defense / 防禦策略)
A01: Broken Access Control	Tested IDOR (changing URL parameters) and SSRF (fetching cloud metadata `169.254.169.254`). Accessed unauthorized data.	Implement strict server-side authorization, deny-by-default policies, and SSRF URL allowlists.
A02: Security Misconfiguration	Identified risks in cloud-native/container misconfigurations and verbose error messages exposing stack traces.	Automated hardening, Policy-as-code, and disabling debug modes in production.
A03: Software Supply Chain	Simulated dependency confusion attacks. Highlighted risks of unverified CI/CD pipelines.	Implement SBOM, dependency pinning, and signature verification.
A05: Injection	Executed OS command injection via diagnostic endpoints (e.g., `ping` command).	Parameterized queries, output encoding, and avoiding direct shell calls.
A10: Mishandling of Exceptional Conditions	Triggered unhandled exceptions in authorization checks, causing a **fail-open** vulnerability.	Implement fail-closed mechanisms, transactional rollbacks, and sanitized error messages.

3. Product Backlog & WBS Planning (產品待辦事項與 WBS 規劃)

Based on Supervisor instructions, the following WBS has been formulated for Phase 1 & 2:

WBS ID	Task Name (任務名稱)	Assignee (負責人)	Status
1.0	**Phase 1: Proposal & Inception (提案與啟動)**	**Team**	In Progress
1.1	Draft Project Proposal (Goals, Scope, Member List)	WONG Lai Man	Pending
1.2	Literature Review (News, Papers, OWASP 2025 Reports)	Mustafa	In Progress
1.3	Format Citations & Reference List (Strict APA 7th)	WONG Lai Man	Pending
2.0	**Phase 2: System Design & Implementation**	**Team**	Pending
2.1	Threat Modeling on Juice Shop Architecture	Zoutao	Pending
2.2	Develop Custom Vulnerable/Remediated Modules (A10/A03)	Zoutao/ Mustafa	Pending
3.0	**Project Management & Reporting**	**Team**	In Progress
3.1	Setup Jira Backlog & Sprint Planning	WONG Lai Man	Completed
3.2	Maintain Bi-weekly Working Journal	WONG Lai Man	In Progress

4. Blockers & Risk Mitigation (阻礙與風險緩解)

Challenge & Technical Gap:

OWASP Juice Shop may not natively cover all specific nuances of the **new OWASP Top 10: 2025** categories (e.g., A10: Mishandling of Exceptional Conditions / fail-open vulnerabilities, or specific A03 Supply Chain scenarios).

Mitigation Strategy:

The team will not rely solely on Juice Shop. We will develop **custom lightweight modules (using Python Flask)** specifically designed to demonstrate 2025 updates (such as A10 fail-open and A02 cloud misconfigurations), integrating them into the main demonstration platform.

5. Action Items & Next Steps (下一步行動與待辦事項)

To fulfill Supervisor requirements for the upcoming Phase 1 submission, the team commits to the following actions by next meeting:

1. **Finalize the Project Proposal Document**: Complete concrete goals, detailed member responsibilities, and scope definition.
2. **Compile Literature Review**: Gather at least 3-5 academic papers or industry news regarding OWASP Top 10 (2021 vs 2025) and Web Application Security.
3. **Strict APA 7th Formatting**: Ensure all in-text citations and reference entries strictly follow HKCT Library guidelines.
4. **Update Working Journal**: Document this bi-weekly meeting and Red/Blue team findings in the official Working Journal.

6. References (APA 7th Format) (參考文獻)

(Note: Preliminary references for Proposal; full list to be expanded.)

1. OWASP Foundation. (2025). *OWASP Top 10:2025: The ten most critical web application security risks*. https://owasp.org/www-project-top-ten/
2. OWASP Foundation. (2021). *OWASP Top 10:2021: The ten most critical web application security risks*. https://owasp.org/www-project-top-ten/
3. Schadler, B., & Klein, A. (2024). *OWASP Juice Shop: Vulnerable web application for security training*. https://owasp.org/www-project-juice-shop/